Action plan

Domain Care Access Navigator - IAM & GRC
Perimeter Mock EHR - Workforce Access Governance
Assessment Healthcare IAM Risk Assessment (R01-R05) — 2.0

Associated applied controls, separated by status and sorted by ETA. 6 in total.

To do (1)

Name	Description	Category	Owner	ETA	Matching items
Security logs are kept 12 months	Security logs are kept 12 months Area: Monitoring / retention HIPAA: 164.316(b)(2) (policy); 164.312(b) NIST CSF 2.0: PR.PS-04 NIST SP 800-53 r5: AU-11 ISO 27001:2022: A.8.15 PCI DSS 4.0.1: 10.5.1 Risks: R03 Evidence: Compliance E-LOG-01 Test: Audit LOG-01 test 3 Test result (2026-11-03): FAIL	Technical	akchrao@gmail.com	-	Care Access Navigator - IAM & GRC/ Healthcare IAM Risk Assessment (R01-R05) - 2.0/Credential compromise

In progress (5)

Name	Description	Category	Owner	ETA	Matching items
Automated Keycloak Leaver Deprovisioning	Implement automated deprovisioning between Microsoft Entra ID and Keycloak so that workforce termination triggers the timely disablement of corresponding Keycloak accounts, revocation of active sessions, and verification of application access removal. Implement reconciliation and alerting to detect accounts that remain enabled after termination. This planned control addresses the deprovisioning gap identified during Jeevan Smith's termination (TERM-2026-0301). Implementation and effectiveness testing are pending. Remediation Validation Plan – R02	Technical	akchrao@gmail.com	-	Care Access Navigator - IAM & GRC/ Healthcare IAM Risk Assessment (R01-R05) - 2.0/Incomplete Leaver Deprovisioning Across Entra ID and Keycloak

Name	Description	Category	Owner	ETA	Matching items
	Objective: Verify that terminating a workforce member in Microsoft Entra ID automatically revokes their Keycloak access and prevents access to the Mock EHR application. Test 1 – Account deprovisioning: Disable a synthetic employee account in Entra ID. Verify that the corresponding Keycloak account is automatically disabled within the organization's defined termination SLA. Test 2 – Session revocation: Confirm that active Keycloak sessions are terminated or invalidated and that the terminated employee cannot reuse an existing application session. Test 3 – Access verification: Attempt to authenticate and access the Mock EHR using the terminated test account. Verify that access is denied. Test 4 – Audit logging: Confirm that termination, account disablement, session revocation, and verification activities are logged with timestamps. Test 5 – Monitoring: Confirm that reconciliation or alerting identifies accounts that remain enabled after termination. Acceptance criteria: All five tests must pass, with supporting screenshots and log evidence. Any failure requires corrective action and retesting. Related finding: CAN-FIND-001 Related risk: R02 Status: Planned – Implementation and validation pending.				
Vendor access is sponsored, time-boxed and removed at expiry	Vendor access is sponsored, time-boxed and removed at expiry Area: Third-party access HIPAA: 164.308(b)(1); 164.314(a) NIST CSF 2.0: GV.SC-07, PR.AA-05 NIST SP 800-53 r5: AC-2(2), PS-7 ISO 27001:2022: A.5.19, A.5.20 PCI DSS 4.0.1: 8.2.7 Risks: R05 Evidence: Service/vendor identity register; TC-08 Test: TC-08 Test result (2026-11-03): PASS	Process	akchrao@gmail.com	-	Care Access Navigator - IAM & GRC/ Healthcare IAM Risk Assessment (R01-R05) - 2.0/Expired vendor access

Name	Description	Category	Owner	ETA	Matching items
Privileged access is approved, limited and monitored	Privileged access is approved, limited and monitored Area: IAM / PAM HIPAA: 164.308(a)(4)(ii)(B) NIST CSF 2.0: PR.AA-05 NIST SP 800-53 r5: AC-2(7), AC-6(5), AC-6(9) ISO 27001:2022: A.8.2 PCI DSS 4.0.1: 7.2.2, 8.2.2 Risks: R04 Evidence: Privileged access matrix; TC-07 Test: TC-07 Test result (2026-11-03): PASS	Technical	akchrao@gmail.com	-	Care Access Navigator - IAM & GRC/ Healthcare IAM Risk Assessment (R01-R05) - 2.0/Privileged account misuse
ePHI and credentials are encrypted in transit (TLS 1.2+)	ePHI and credentials are encrypted in transit (TLS 1.2+) Area: Data protection HIPAA: 164.312(e)(1), (e)(2)(ii) NIST CSF 2.0: PR.DS-02 NIST SP 800-53 r5: SC-8, SC-8(1) ISO 27001:2022: A.8.24 PCI DSS 4.0.1: 4.2.1 Risks: R03 Evidence: Compliance E-ENC-01 Test: Audit ENC-01 tests 1-4 Test result (2026-11-03): PASS (Azure); EXCEPTION (IdP)	Technical	akchrao@gmail.com	-	Care Access Navigator - IAM & GRC/ Healthcare IAM Risk Assessment (R01-R05) - 2.0/Credential compromise
Privileged and cardholder-data users pass MFA	Privileged and cardholder-data users pass MFA Area: Authentication HIPAA: 164.312(d) NIST CSF 2.0: PR.AA-03 NIST SP 800-53 r5: IA-2(1), IA-2(2) ISO 27001:2022: A.8.5 PCI DSS 4.0.1: 8.4.1, 8.4.2 Risks: R03 Evidence: EV-13 verify (MFA_REQUIRED) Test: W5 verify; TC-03 Test result (2026-11-03): PASS	Technical	akchrao@gmail.com	-	Care Access Navigator - IAM & GRC/ Healthcare IAM Risk Assessment (R01-R05) - 2.0/Credential compromise

Generated at 2026-11-09 17:33:13 UTC
Document ID `dcf0b5f0-1ca0-448c-b8bd-a05b4f7b7dbc`